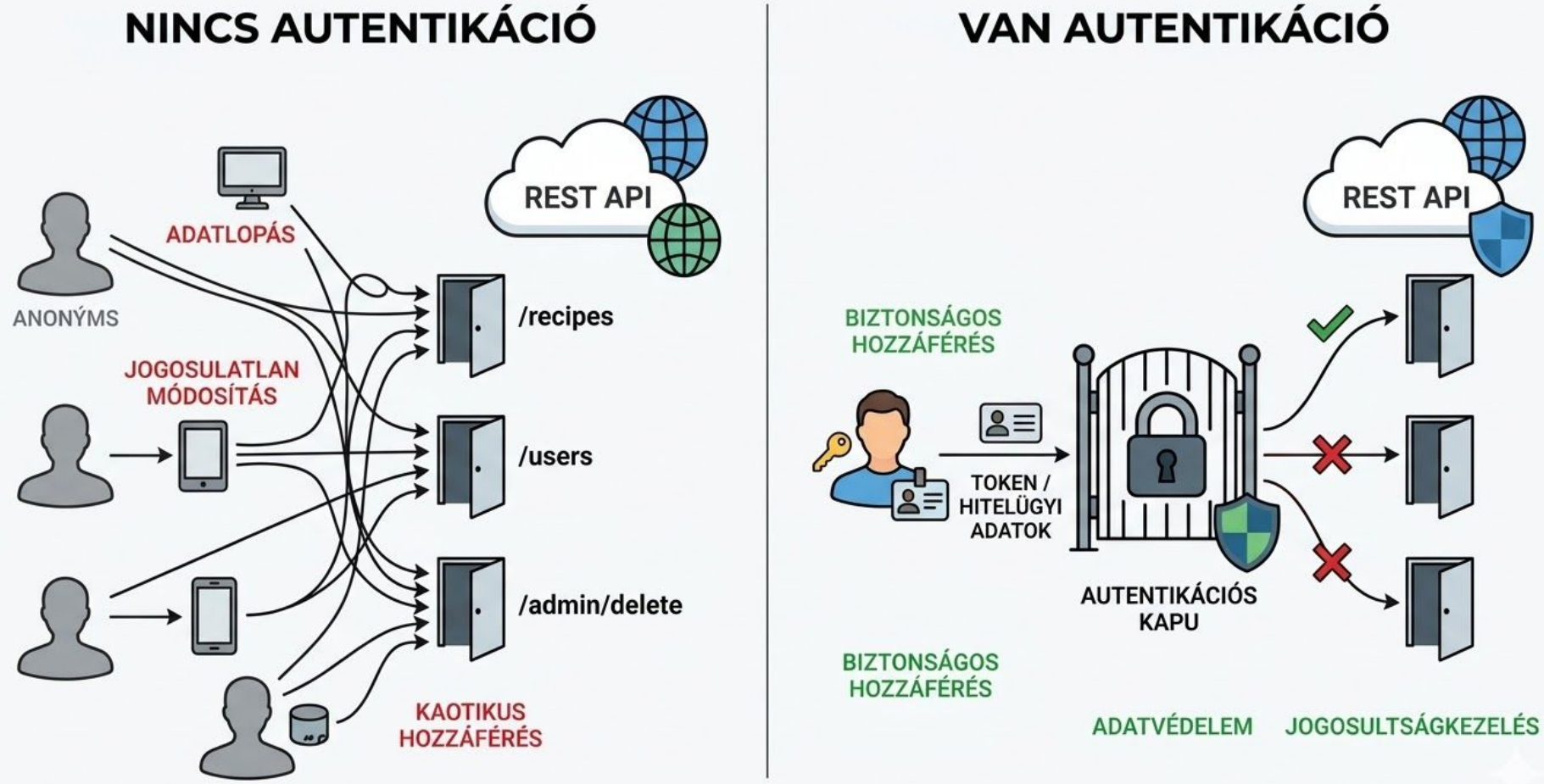
UNIVERSITY OF SZEGED
Department of Software Engineering
UNIVERSITAS SCIENTIARUM SZEGEDIENSIS

Programrendszerek fejlesztése

5. gyakorlat

Dr. Jánki Zoltán Richárd

Autentikáció fontossága



Autentikáció vs. autorizáció

Jelszókezelés alapelvei

- Jelszavak adatbázisban történő tárolása
  - Plain text formában soha!
  - Csak titkosítás NAGYON(!) indokolt esetben, inkább soha!
  - Használjunk hash algoritmust
- Jelszavak komplexitása
  - Minimum hossz megkövetelendő
  - Hash paraméterek növelése
- 3rd-party (provider-alapú) megoldások
  - Felelősség nem a mi kezünkben van (pl.: Google, Apple, stb.)
  - Sokszor kényelmesebb a felhasználóknak is

Regisztráció folyamata

1. A kliens elküldi a felhasználónevet, email-t, jelszót (HTTP POST body)
2. Szerver ellenőrzi a felhasználónév, email foglaltságát
3. A jelszó hash-elésre kerül (pl.: bcrypt)
4. Az új felhasználó objektum a hash-elt jelszóval elmentődik az adatbázisba.
5. A szerver visszajelez, hogy a regisztráció sikeres volt.

Bejelentkezés folyamata

1. A kliens elküldi a felhasználónevet, email-t, jelszót (HTTP POST body)
2. Szerver megkeresi a felhasználót
3. Ha létezik, akkor a kliens által küldött jelszót hash-eljük (pl.: bcrypt)
4. Összehasonlítjuk a két hash-t (kliens vs. adatbázis).
5. Ha megegyezik a két hash, a szerver generál egy tokent, és visszaküldi a kliensnek.

JSON Web Token (JWT)

- 3 részből áll:
  - header (algoritmus, típus)
  - payload (azonosító, szerepkör, lejárati idő)
  - aláírás (a szerver titkos kulcsával aláírva)

1 2
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWF0IjoxNTE2MjM5MDIyfQ.XbPfbIHMI6arZ3Y922BhjWgQzWXcXNrz0ogtVhfEd2o 3

1 Header

```
{
  "alg": "HS256",
  "typ": "JWT"
}
```

2 Payload

```
{
  "sub": "1234567890",
  "name": "John Doe",
  "iat": 1516239022
}
```

3 Signature

```
HMACSHA256(
BASE64URL(header)
.
BASE64URL(payload),
secret)
```

Token-alapú autentikáció működése

- A sikeres bejelentkezés után a kliens megkapja a tokent.
- A kliens minden kéréséhez csatolja a tokent a kérés fejlécében (`Bearer $TOKEN`)
- Előnyök
  - állapotmentes
  - nincs szükség session-re
  - skálázható